ПРУФ-ИТ / PROOFIT

Модель угроз и злоупотреблений

Активы, доверительные границы, abuse cases и проверяемые меры.

Редакция документа: 11 октября 2026. Архитектурные утверждения связаны с указанными модулями; числовые результаты — с протоколами измерений, их датами и областью применимости. Обновление документа не означает повторного проведения всех экспериментов.

Роли: специалист, работодатель, явно одобренный эксперт. Окончательное решение о найме, трактовка спорного evidence и разрешение на обработку данных не передаются автономному score.

1. Область и метод

Модель охватывает web/API, identity, хранилище резюме, квалификацию, graph projection, sandboxes, очереди, provider gateways и portable proof. Метод — STRIDE для технических угроз, privacy-анализ по жизненному циклу данных и abuse-case анализ стимулов кандидата, работодателя и reviewer. Подход к проверке контролей сопоставлен с OWASP ASVS; формальная сертификация ASVS не заявляется. [ASVS]

Риск приоритизируется как likelihood×impact на авторской шкале 1–5; это экспертная порядковая оценка для планирования проверок, не статистическая вероятность взлома. Риск ≥16 требует приоритетного контроля; 9–15 — наблюдения и эксплуатационных мер. Приведены исходные риски, реализованные барьеры, проверки и обязанности оператора. Отсутствие зарегистрированной ошибки в тестах не равняется отсутствию угроз.

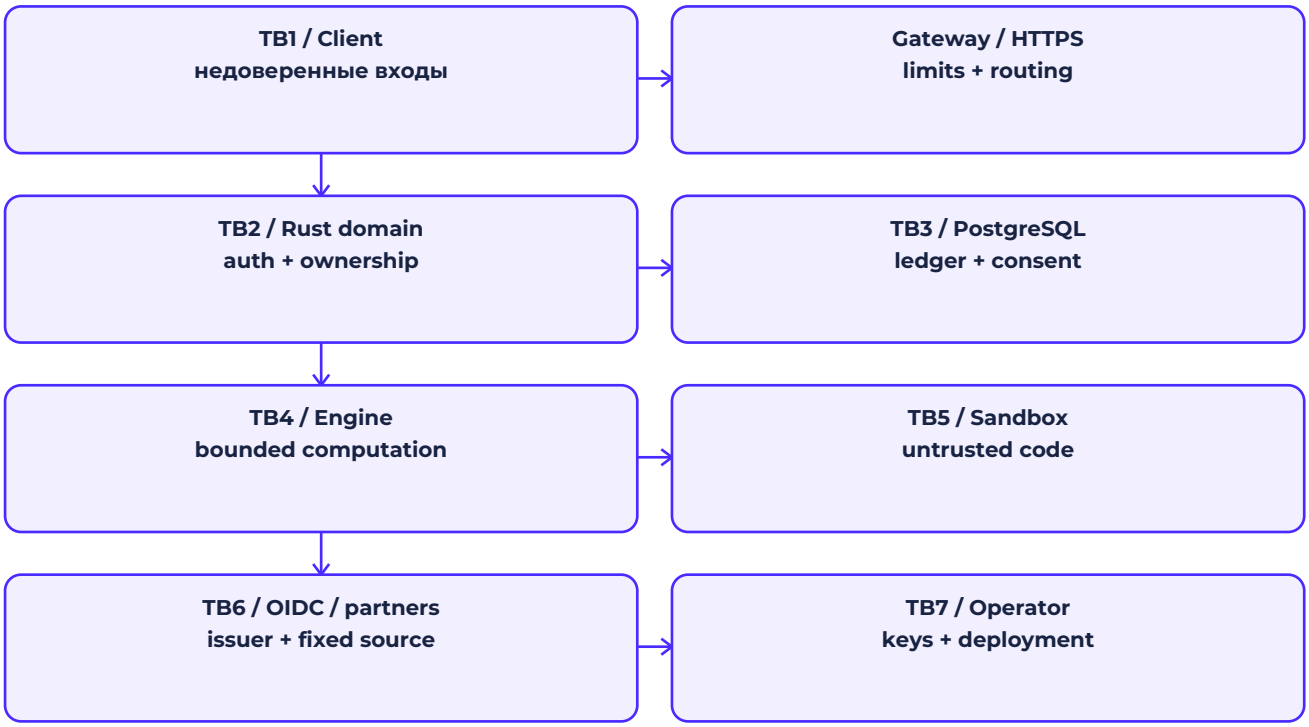
2. Активы и нежелательные исходы

A1: учетная запись и session; A2: документы, контакты и согласия; A3: qualification certificate / response trace; A4: evidence graph; A5: условия вакансий и приглашения; A6: submitted code / hidden tests; A7: OIDC/partner/integration/key secrets; A8: доступность retrieval и очередей; A9: исходы 30/60/90; A10: audit/provenance.

Нежелательные исходы: несанкционированное раскрытие, ложная квалификация, неправомерное понижение, незаметная подмена provenance, исполнение кода на хосте, захват reviewer-прав, неисправимый отзыв portable proof, дискриминационное решение, потеря состояния и отказ общего поиска из-за дорогого задания.

3. DFD и границы доверия

TB1 браузер → публичный gateway: все входы недоверенные. TB2 gateway → private domains: домен повторяет auth и ownership; forwarded IP доверяется только заданному proxy. TB3 Rust → PostgreSQL: параметризованные запросы и транзакции. TB4 Rust → intelligence/workbench: внутренние секреты и bounded contracts. TB5 executor → container: код не доверен. TB6 сервис → Keycloak/provider: проверка issuer, подписи и фиксированного источника. TB7 operator → конфигурация: секреты, ключи, backup и размещение.



4. Нарушители и возможности

Внешний неаутентифицированный субъект пытается подобрать доступ или перегрузить вход. Авторизованный кандидат может редактировать профиль, подавать ответы и код, но не сертификаты и чужие объекты. Работодатель может создавать свои вакансии и запросы, но не private candidate data. Reviewer имеет только явно одобренную функцию разбирательства. Недоверенный файл или AI-ответ может содержать инструкции, но не получает права на execution/tool access.

Компрометация хоста, Docker daemon, DB superuser, ключа issuer или operator account находится выше прикладного ownership-периметра. Защита требует отдельной изоляции и эксплуатации; приложение не объявляется защитой от администратора своей же машины. Такой предел нужен для корректного выбора мер, не для исключения неудобных угроз.

5. Реестр угроз и evidence-based mitigation

ID / риск	Сценарий	Реализованный барьер	Проверка / эксплуатационная мера
T01 / S	Захват учетной записи; 4×5	Argon2; подтверждение email; IP/account throttle; отзыв auth_epoch; Keycloak brute force	test_api.py: register/verify/reset/session; оператор: MFA и SMTP
T02 / S	Подмена OIDC identity; 3×5	PKCE S256, state, nonce, JWKS, iss/aud, browser binding, одноразовое состояние	test_professional_http.py: настоящий Keycloak, replay, другой субъект
T03 / T	SQL-инъекция; 3×5	Параметризованный SQLx; whitelist dynamic fields; ownership в WHERE	Role/ownership HTTP; code review matching / evidence
T04 / I	Чтение чужих PDF; 4×5	user_id scope, UUID storage key, файл вне web root	test_api.py: forbidden чужой документ / отсутствие storage_key
T05 / I	Контакты до согласия; 4×5	Отдельные processing/publication/contact gates; accepted invitation; revoke	test_api.py: offers/contact isolation; test_private_conversations.py
T06 / I	Private proof через public graph; 3×5	Published searchable source resume; evidence controls; live cert scope	test_evidence_http.py: private certificate не раскрыт
T07 / T	Повышение грейда редактированием; 4×4	Immutable role/grade certificate; 90-day guard; scoped ledger	test_resume_qualification.py: edit/new resume/cooldown
T08 / T	Replay / гонка ответа CAT; 4×4	row lock + question_id + revision; серверное время; current item only	Live qualification replay; hidden answer key tests
T09 / I	Утечка банка или hidden tests; 3×4	Публичный current item; contracts redacted; scored traces после завершения	test_workbench.py; qualification / arena HTTP
T10 / T	Накрутка графа повторением; 4×4	Max per source class; execution объединяет arena и sandbox; declared weight=0	CPU duplicate/cap tests; main ranking graph projection
T11 / T	Плагиат / padding / шаблон; 4×4	Task/language/version scope, template subtraction, containment, manual review	120 controlled transformations; 3 independent implementations
T12 / E	Самоодобрение / ложный reviewer; 3×5	approved expert flag; user_id ≠ reviewer; reason; challenge	test_evidence_http.py: unapproved и self-review rejected
T13 / T	Поддельный portable proof; 3×5	Ed25519, fixed alg/aud/iss, digest, expiry, live revocation	CPU signature tamper; HTTP hide/revoke/passport ownership
T14 / E	Побег исполняемого кода; 3×5	Non-root, network none, read-only, caps dropped, no-new-privileges, no mounts/secrets	test_workbench.py / horizon SQL Docker; host kernel isolation требуется
T15 / D	Fork bomb / infinite loop / output flood; 4×4	2 slots, 0.5 CPU, 128 MB, 32 PID, ограничение FD/output/time, cleanup exact container	Sandbox bounded contract; эксплуатация: patch Docker / host

ID / риск	Сценарий	Реализованный барьер	Проверка / эксплуатационная мера
T16 / T	Prompt injection из PDF / кода; 4×4	Недоверенный текст не дает tool privilege; review полей; AI не меняет обязательный cert	CPU mandatory CAT; ownership контур; human reviewed extraction
T17 / I	SSRF внешнего provider; 3×5	Фиксированный operator endpoint HTTPS; no redirects; timeout; limit body; source host validation	Provider CPU negative URL / origin / ranges
T18 / T	Выдуманный рейтинг / достижение; 4×4	Не подключенный provider → neutral; signed identity ≠ achievement; verified snapshot contract	HTTP not_connected ranking_effect=0; source URL tests
T19 / D	HTTP flood / тяжелая загрузка; 4×4	Gateway slots/upload/body/circuit-breaker; domain quotas; separate queues	30-session bounded HTTP; внешний edge rate limit для production
T20 / R	Отрицание операции / спор; 3×4	Audit actions, certificate history, independent review reason и challenge	Persisted traces; журнал не объявлен неизменяемым WORM
T21 / I	Секреты в репозитории / bundle; 3×5	Ignored runtime, *_SECRET_FILE, independent key material, source package exclusions	Manifest / repository scan; оператор: file ACL и key rotation
T22 / T	Data poisoning / псевдокалибровка; 3×4	Авторский статус параметров; pilot exclusion; expert activation; versioned frozen model	Pilot minimum cases + occupied bins; holdout без retune
T23 / D	Потеря процесса / lease; 3×4	Persisted jobs, heartbeat, fenced completion, SKIP LOCKED	test_horizon_http.py: stale worker / queue contract
T24 / I	Inference о чувствительных свойствах; 3×5	Preference whitelist; no personality inference; PII не вход twin/ranking	Prohibited fields / preferences privacy / sensitive_features_used=[]
T25 / I	Неподходящее размещение ПДн; 3×5	Локальный data plane; публичный tunnel — отдельный demo transport; auth и HTTPS	Оператор определяет правовое основание, локализацию, договоры и трансграничные условия
T26 / T	Назначить человека дважды; 4×3	candidate identity grouping; best resume per slot; dummy slots	Exhaustive CPU oracle и multi-resume assignment test
T27 / I	Утечка followup третьей стороне; 3×4	Invitation participants scope; independent candidate/employer fields	HTTP 30/60/90 bilateral + third-party denied
T28 / D	Компрометация dependency / image; 3×5	Lock-файлы, pinned versions; download SHA; CI compile/tests	Локальная сборка / проверка connector; оператор: registry scanning и SBOM

6. Abuse trees: сертификат, граф, контакт

Цель «ложный senior»: изменить declared_grade → immutable snapshot/90-day guard; создать другое резюме → candidate scope ledger; повторить submit → revision/CAS; раскрыть ключ → current-item DTO; скопировать код → task-scoped signal + independent review. Все пути проверяются отдельно: одного ограничения UI недостаточно.

Цель «увидеть private skill»: найти публичное резюме того же человека → source-resume visibility; прочитать graph endpoint → consent + verified employer; выдать скрытый certificate в passport → evidence controls; использовать старый token → live digest/cert guard. Цель «получить контакт»: найти карточку → public DTO без контакта; создать offer → контакт после согласия; отозванное согласие → блокирование дальнейшего открытия.

7. Privacy threat analysis

Linkability: portable proof не содержит имени и контактов, но набор навыков может косвенно связать человека; передачу token контролирует владелец. Identifiability: минимизация данных в twin/LLM prompts и public DTO. Detectability: системные ошибки не выдают существование чужого объекта за пределами ownership. Disclosure: file routes требуют владельца. Unawareness: source/status/consent должны быть понятны в UI. Non-compliance: размещение, retention и договоры определяет оператор.

Контроль справедливости не ограничивается отсутствием protected columns: навыки, зарплата, опыт и граф могут косвенно коррелировать с группами. Текущие тесты подтверждают whitelist и отсутствие прямого ввода чувствительных признаков; равенство outcome across real demographic groups не объявляется измеренным без правомерно собранной выборки.

8. Пределы защиты и критерии повторного анализа

Повторная модель угроз обязательна при новой роли, внешнем provider, remote executor, изменении контактного consent, новой LLM с tool access, новой source class и переносе в public production. Базовая частота — каждый существенный release; owner изменения проверяет affected invariants и negative tests.

Production prerequisites: TLS + restricted admin, независимые secrets/rotation, host hardening и patching, контролируемое хранение и backup, distributed rate limiting, monitoring, регламент инцидентов и обработка запросов субъекта данных. Quick Tunnel не является промышленным ingress с SLA; отсутствие сетевого входа в sandbox не отменяет риск kernel/container escape.

9. Приемка модели угроз

Техническое доказательство — test name + persisted artifact + source hash. Эксплуатационное доказательство — проверенная конфигурация, журнал изменения и ответственный. Юридическое доказательство — политика, основание обработки, договоры и уведомления, когда применимы. Эти классы evidence не подменяют друг друга. Набор negative tests расположен в tests/test_api.py, test_evidence_http.py, test_resume_qualification.py, test_professional_http.py и test_horizon_http.py.

10. Контроль подмены категории и контекстного доступа

Атакующие поверхности: promotion self-report, future/null date, сертификат другого субъекта/роли, восстановление revoked proof через legacy flag, повторный idempotency key с другим резюме и извлечение зарплаты из малого пула. Контроли: единственная SQL projection, binding всех ключей, fail-closed даты, отсутствие fallback при наличии сертификата, payload fencing и minimum cohort=5. Pending signal не запускает автоматическое обвинение; independent finding и appeal сохраняют различимые состояния.

11. 34–38. Целостность измерений и разрешённый контекст

T34: post-outcome prediction — серверный ledger, first-intention check, сериализация пары и серверные timestamps. T35: переписывание outcome — immutable trigger и отдельная запись первого парного результата. T36: synthetic-as-human — маркировка, исключение из real report, unknown metrics и независимая проверка происхождения внешнего cohort. T37: role mixing / unlimited peeking — role/grade/version protocol, один финальный paired analysis, order blocks и explicit SRM. T38: подмена рыночного origin или прав — allowlist, operator manifest с period/product scope, отсутствие запроса без прав, strict ISS schema и нулевое влияние до temporal ablation. Delete/cascade сохраняются для законного удаления ПДн; immutable не означает бессрочное хранение.

12. 29–33. Расширенные abuse cases

T29: SSRF и подмена публичного origin GitHub — фиксированный api.github.com, строгий PR path, запрет redirects и ограничение тела. T30: выдача чужого вклада — one-time gist, immutable SHA/digest, CAS и независимый reviewer. T31: ложное обвинение по таймингу — только review signal, альтернативные объяснения и appeal. T32: неразрешённые рыночные источники — licensing_required и нулевой forecast/ranking effect. T33: изменение смысла согласия при локализации — exact keyset, numeric/operator checks и отдельная ручная проверка критичных privacy/auth строк. Каждая мера имеет область проверки; машинный перевод не выдаётся за полную лингвистическую экспертизу.

13. Единый авторизованный контур проверки

Проверка платформы выполняется через штатную авторизацию: по отдельно переданным данным тестовых кабинетов либо после собственной регистрации. Сессия, серверная роль и принадлежность данных проверяются обычными обработчиками. Вход в другую роль требует учетных данных ее кабинета; гостевого входа, автоматической смены identity и анонимной выдачи паролей нет. Синтетические резюме и вакансии сохраняются без пересоздания пользователей. Прежние гостевые сессии отозваны миграцией 0030 без удаления данных. Такая организация делает границы доступа частью проверяемого пользовательского маршрута. Протокол и область измерений — 11_Interface_and_Demo.pdf.